

Infrastructure Security Audit

Kubernetes · Talos · Tailscale · Cloudflare · Workloads

Torvalds homelab · 19 July 2026

Executive verdict

The environment has a credible security foundation, but several deployed controls provide less protection than their configuration suggests. The clearest example is network isolation: 49 NetworkPolicy objects exist, yet no live controller enforces them.

No Critical finding, active compromise, authentication bypass, or unauthenticated Internet-to-node path was confirmed. Seven High findings do create realistic paths from a compromised public workload, same-repo CI job, or trusted controller to cluster or node control. Short-lived local audit logs and untested recovery would magnify the impact.

0

Critical

7

High

14

Medium

4

Low

66

Argo apps

49

Policy objects

Source of truth: repository decision record. Raw exploit procedures and sensitive topology are deliberately excluded from this public-safe rendering.

The decisions that matter now

The first wave is about restoring **real boundaries**: enforce declared isolation, separate build execution from cluster control, patch the tailnet, and preserve evidence and recovery options.

No.	Action	Why now	Risk
1	Enforce NetworkPolicy	Existing policies have no effect without a controller.	High
2	Split Buildkite identities	Job pods currently inherit controller RBAC in a privileged namespace.	Medium
3	Patch Tailscale	Every device is below 1.98.9; bulletin exposure depends on enabled features.	Low
4	Reduce crown-jewel RBAC	1Password, Alloy, Cloudflare operator, and SeaweedFS carry broad cluster authority.	Medium
5	Protect Argo and receivers	Public request handling terminates near cluster-wide credentials.	Medium
6	Export audit logs and restore	About 3.6 hours of local evidence and zero observed Restore objects are inadequate.	Medium

Strong controls worth preserving

Host and control plane

Talos immutable host; unified kernel image; module signatures; hardened eBPF/ptrace; seccomp default; API anonymous auth off; Secret encryption at rest; audit Metadata enabled.

Identity and edge

Tailscale deny-by-omission policy with tests; no Funnel or subnet routes; Cloudflare strict TLS on most zones; DNSSEC active on nine of ten zones.

Build and artifacts

Fork PR builds disabled; repository secret scanning and push protection enabled; blocking Gitleaks; many first-party images pinned by digest.

Backup signal

Four Velero schedules; 26 retained Backup objects completed; latest run completed all 42 attempted snapshots. This is backup evidence, not restore evidence.

Confirmed High findings

“Design risk” means a real, high-impact trust path exists even though no current bypass or compromise was demonstrated.

F-02 CI reaches cluster control

Branch-controlled Buildkite jobs receive broad Secrets, mount the controller identity, and can create Jobs where privileged workloads are permitted. Fork builds are disabled.

F-03 Unsigned GitOps trust

An authenticated chart publisher can feed moving, unsigned artifacts into automated sync; wildcard AppProjects permit privileged and cluster-scoped resources.

F-05 Cloudflare operator authority

A third-party alpha controller can read and write every cluster Secret and mutate workloads. Its image is tag-only and its authority is not limited to tunnel resources.

F-08 Public receivers share credentials

Three authenticated public routes terminate in a Temporal worker holding numerous infrastructure credentials and selected exec rights. Authentication tested fail-closed.

F-09 SeaweedFS escalation

The storage identity can create Pods cluster-wide while infrastructure namespaces permit privileged workloads. No misuse or active compromise was demonstrated.

F-10 Recovery is unproven

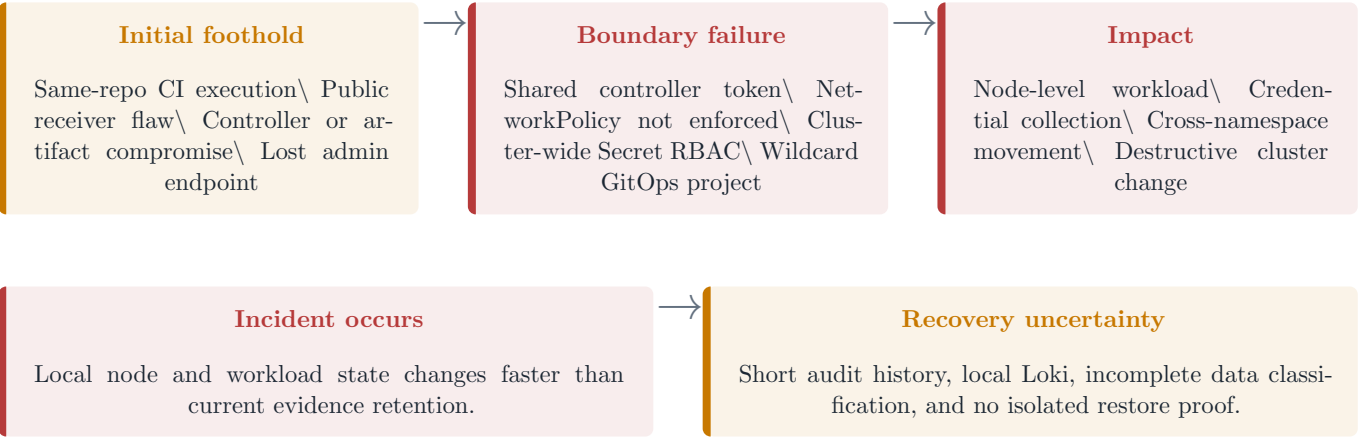
Zero Restore objects, 20 unlabeled PVCs, inconsistent database coverage, no automated etcd snapshot or restore evidence, and no observed consistency hooks leave RPO/RTO unknown.

F-12 1Password controller authority

The operator can mutate cluster-wide Secrets, namespaces, Pods, and application controllers while Connect holds access to synchronized vault items.

How the risk compounds

The major issue is not one exposed service. It is the combination of reachable parsing surfaces, high-trust identities, unenforced segmentation, and weak post-incident evidence.



Medium-risk themes

Theme	Observed posture
Network isolation	Flannel lacks a separate policy controller; 49 NetworkPolicy objects are ineffective until enforcement is installed and behaviorally tested.
Boot and physical	Secure Boot and disk encryption off; SELinux permissive; lockdown integrity is an intentional eBPF trade-off.
LAN and host	Control-plane listeners bind broadly; no Talos ingress firewall; router administration needs authenticated review.
Admission	Baseline enforcement is active; restricted is advisory, privileged exceptions exist, and custom API-boundary policy is narrow.
Artifact trust	Many tag-only images; no required SBOM, signature, provenance, or admission-verification chain.
Edge patching	Tailscale is below the feature-specific bulletin floor; cloudflared is unsupported and drifted from declared state.
Admin surface	Internet requests reach Argo’s authenticated local-admin login; no bypass was found and default rate limiting appears active.
Observability trust	Alloy combines intended node privilege with unnecessary all-Secret reads; audit logs remain short-lived and node-local.
Application pivots	Broad HA proxy trust, shared Tailscale proxy Secrets, and unsandboxed PinchTab need containment.
Availability	Single node, no quotas, incomplete limits, and persistent GitOps drift couple outages to security response.
Detection	No workload-aware runtime sensor; event export is ineffective; paging is single-person and fatigue-prone.

Remediation sequence

0–72 hours — reduce immediate exposure

- Upgrade all Tailscale clients, prioritizing administrator and SSH endpoints.
- Split Buildkite controller and job service accounts; remove job RBAC and token mounting.
- Remove or isolate Alloy Secret access, SeaweedFS Pod authority, and 1Password’s cluster-wide workload scope.
- Put Argo behind Access or the tailnet, establish SSO, and retire routine built-in admin use.
- Deploy a supported digest-pinned cloudflared release and reconcile source/live drift.
- Preserve current audit logs and backup metadata; do not delete orphan-looking snapshot objects.

Within 7 days — create real boundaries

- Install and behaviorally validate a NetworkPolicy enforcer, one namespace at a time.
- Split public Temporal receivers from privileged workers and credentials.
- Replace or sharply scope the Cloudflare operator.
- Ship Kubernetes audit logs to independently protected off-node storage.
- Disable/authenticate filer S3; correct Home Assistant proxy trust.
- Explicitly classify all 66 PVCs as protected or intentionally disposable.

Within 30 days — prove trust and recovery

- Run isolated etcd, Talos, and database-backed application restore drills.
- Create least-privilege AppProjects; pin and sign chart artifacts.
- Generate SBOM/provenance, sign images, and enforce verification for privileged workloads first.
- Roll out workload-class admission policies and service-account-token defaults.
- Segment PinchTab and Tailscale proxy identities; remove dormant Dagger resources.
- Establish high-value runtime/event detection and an owned incident triage path.

Sequence dependency

Network enforcement has the highest outage risk because existing policy objects have never been exercised. Observe traffic, stage by namespace, test both allowed and denied paths, and keep an explicit rollback. Restore evidence should be captured before broad policy and identity changes.

Scope, assurance, and open evidence

What was verified

- Repository intent and live Kubernetes/Talos/Argo/Tailscale/Cloudflare metadata were reconciled.
- All 66 Argo Applications and 166 long-running workload controllers were inventoried at the timestamped snapshot.
- Workload security context, RBAC, service-account, exposure, image, storage, backup, and admission posture were aggregated with targeted application reviews.
- Low-impact route, TLS, redirect, and authentication checks were performed. No exploit was attempted.
- Read-only checks generated ordinary access/audit logs and may have incremented authentication or rate-limit counters; no stored configuration or workload state was intentionally changed.
- Official current guidance and advisories were checked for the core control-plane, edge, CI, GitOps, supply-chain, and recovery technologies.

What remains an access gap

- Cloudflare account membership/MFA, dashboard Access/WAF/rate-limit rules, registrar lock, and R2 retention controls.
- Router firmware, WAN administration, HTTPS, port forwards, UPnP/WPS, IPv6 firewall, and network segmentation.
- TPM/IOMMU capability, physical console protection, firmware revision, and recovery-key custody.
- Buildkite organization membership/roles/audit; 1Password membership/scopes/recovery/events.
- Application databases, plugin inventories, browser profiles, backup contents, and Secret values.
- Behavioral NetworkPolicy tests, a real restore, and representative LAN reachability.

Evidence standard

“Confirmed” means live state or two corroborating signals supported the claim. “Design risk” means the privilege and path are real, but no bypass or compromise was demonstrated. Missing access is recorded as an access gap, never assumed absent.

Bottom line

The homelab is not in an emergency state. Its immediate security work is nevertheless concrete: some declared boundaries are not real, and several trusted components carry more authority than their role requires. Fixing enforcement and identity separation first will reduce the value of a single application compromise. Durable evidence and tested recovery then turn a severe incident from an uncertain rebuild into a controlled operation.

NEXT: REMEDIATION WAVE 1

Network-policy enforcer · Buildkite identity split · Tailscale patching · crown-jewel RBAC